ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Rockwell Stratix 5700 / 5200 Managed Industrial Switch · Component type: **Network Device (NDR)** · Target SL = SL 3

Where to work	**IOS / IOS-XE CLI** (console + SSHv2); **Device Manager** (HTTPS web) & **Studio 5000 Add-on Profile** (AOP) for Logix integration; RADIUS/TACACS+. Express Setup button / SD card for provisioning.
Interfaces / ports	**SSH 22**; **HTTPS 443** (Device Manager); **Telnet 23** (disable); **SNMPv3 161**; **EtherNet/IP CIP 44818** (Logix/AOP); RADIUS 1812/1813; TACACS+ 49; NTP 123; Syslog 514; console.
Firmware note	**Stratix 5700 = IOS** (15.2(x)EA), **Stratix 5200 = IOS-XE** (17.x). Feature set/commands vary slightly; MACsec/advanced features license-dependent. Confirm catalog (1783-BMS/HMS or 1783-MMS) and version with `show version`.
How to read	Default read-only (show / Device Manager view). Native CLI/WebUI how-to + external-tool validation + pass. Write/exploit tools = **isolated/representative env + written authorization**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.1	Human user I&A;	AAA on: `show run | sec aaa` (`aaa new-model`); SSH-only lines (`transport input ssh`, `ip ssh version 2`), Telnet disabled; `no ip http server` + `ip http secure-server` (Device Manager over HTTPS). In Device Manager confirm admin login required. **Test:** console/SSH/HTTPS without creds -> denied. **Ext. tools:** SSH client; browser (HTTPS Device Manager); RADIUS/TACACS+ test; Nmap; ReadOnlyEnum.	All mgmt interfaces authenticate; Telnet/HTTP disabled; no default/anonymous access.	Change Express-Setup default admin.
SR/CR 1.2	Device & software-process I&A;	802.1X/MAB on access ports (`show authentication sessions`); MACsec where supported (`show mka sessions`); restrict the **CIP/EtherNet-IP** management interface to the Logix EWS. SNMPv3 only. **Test:** rogue endpoint on an 802.1X port denied/quarantined. **Ext. tools:** 802.1X supplicant; Wireshark (EAPOL/MKA; enip on 44818); RADIUS logs.	Only authenticated devices connect; CIP mgmt limited to trusted hosts.	
SR/CR 1.3	Account management	Named accounts (`show run | sec username|aaa`); `service password-encryption`; `enable secret` / `username x secret` (type 8/9, no type-0/7). Remove Express-Setup defaults. **Ext. tools:** Config review (weak-hash grep); ISE/AAA review.	Named, least-priv accounts; strong secrets; no defaults.	
SR/CR 1.4	Identifier Management	Confirm identifiers (user and device IDs) are unique, not reused, and managed over their lifecycle.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.5	Authenticator management	Confirm authenticators (passwords, keys, certs) are managed, protected and rotated; defaults changed. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Authenticator management verified individually.	
SR/NDR 1.6	Wireless Access Management	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 1.7	Strength of password auth	`aaa common-criteria policy` / `security passwords min-length`, or AAA/ISE policy. **Ext. tools:** AAA/ISE policy review.	Strong configurable password policy enforced.	
SR/CR 1.8	Public key infrastructure	`show crypto pki certificates` (Device Manager cert CA-signed); `show ip ssh` (KEX/cipher). Replace self-signed default. **Ext. tools:** sslscan (:443); ssh-audit (:22).	CA-signed cert; strong keys/ciphers.	
SR/CR 1.9	Strength of Public Key Authentication	Confirm public-key / certificate authentication uses strong keys and algorithms (>=2048 RSA / ECC).	Met per SL-3 - verify on the product and capture evidence.	completeness

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 1.10	Authenticator Feedback	Confirm authenticators (passwords) are obscured during entry (masked) on every interface.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 1.11	Unsuccessful login attempts	`login block-for 100 attempts 3 within 60` + `login on-failure log`; verify `show login`. **Ext. tools:** Hydra/Medusa (ISOLATED, authorized).	Lockout/quiet-mode on excess failures; logged.	
SR/CR 1.12	System Use Notification	Confirm an approved system-use / logon banner is displayed before access on each interface.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/NDR 1.13	Access via untrusted networks	VTY `access-class` ACL, management VLAN/OOB, SSH-only; no mgmt or CIP reachable from untrusted VLANs; remote via jump host. **Ext. tools:** Nmap from each VLAN (22/443/44818); ACL review.	Mgmt/CIP unreachable from untrusted; brokered remote access.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 2.1	Authorization enforcement	TACACS+ command authorization (`aaa authorization commands 15`) / privilege levels / `parser view`; Device Manager role. **Test:** low-priv user cannot enter config. **Ext. tools:** TACACS+ command-auth logs.	Least privilege enforced; unauthorized commands denied/logged.	
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 2.3	Use Control for Portable and Mobile Devices	**N/A.** Device does not host portable/mobile-media use; USB/portable-device use is controlled at the engineering host (EWS).	N/A - justification recorded (not assessed as a control).	N/A
SR/NDR 2.4	Mobile Code	Assess per objective: Enforce usage restrictions for mobile code technologies.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.5	Session lock	`exec-timeout 10 0` on console/vty; Device Manager idle timeout. **Ext. tools:** Manual idle test.	Idle sessions time out.	
SR/CR 2.6	Remote Session Termination	Confirm remote sessions can be terminated on demand and on inactivity timeout.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.7	Concurrent Session Control	Confirm concurrent-session limits or monitoring for privileged/engineering access.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.8	Auditable events	AAA accounting + `archive` / `log config` / `logging enable` + `notify syslog`; central syslog. **Test:** change config -> syslog + `show archive log config all` with user. **Ext. tools:** Syslog server.	Security events logged with user + timestamp.	
SR/CR 2.9	Audit Storage Capacity	Confirm audit/log storage is sized and rotated and alerts before overflow (or offloads to syslog/SIEM).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.10	Response to Audit Processing Failures	Confirm defined behavior on audit/log processing failure (alert; do not silently drop events).	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 2.11	Timestamps	`service timestamps log datetime`; authenticated NTP (`ntp authenticate`); AAA accounting + config archive tie changes to a named user. **Ext. tools:** Wireshark (NTP); TACACS+ accounting review.	Synced time; changes attributable to named users.	
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.11** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
NDR 2.13	Physical Diagnostic/Test Interfaces (Network)	Assess the NDR-specific requirement per objective: Network device shall protect against unauthorized use of physical diagnostic and test interfaces.	Met per SL-3 - verify and capture evidence.	NDR completeness

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 3.1	Communication integrity	Mgmt via SSH/HTTPS/SNMPv3 only; MACsec on trunks where supported; `control-plane` protection; no cleartext mgmt. **Ext. tools:** Wireshark (encrypted mgmt; MACsec); Nmap.	Mgmt integrity-protected; cleartext protocols off.	
SR/NDR 3.2	Protection from malicious code	Load only signed Rockwell/Cisco firmware; verify image (`verify /md5`; 5200: `show software authenticity running`); restrict firmware update to admins. **Ext. tools:** Hash cross-check vs vendor.	Only signed firmware runs; integrity verified.	
SR/CR 3.3	Security functionality verification	Compare running config vs baseline; protect/hash image; restore from trusted archive (`configure replace`). **Ext. tools:** RANCID/Oxidized (config drift).	Config matches baseline; drift detected; image integrity verified.	
SR/CR 3.4	Software & information integrity	Confirm software & information (config/program) integrity; unauthorized change prevented/detected. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Software & information integrity verified individually.	
SR/CR 3.5	Input Validation	Assess per objective: Validate syntax and content of any process control input.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.6	Deterministic Output	**N/A.** Device does not drive process outputs; deterministic/fail-safe output is not applicable.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 3.7	Error Handling	Confirm errors are handled gracefully without leaking sensitive information or losing control.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 3.8	Session integrity	Strong SSH/TLS; disable weak SSH algos (`ip ssh server algorithm ...`). **Ext. tools:** ssh-audit; sslscan.	Strong session crypto; weak algorithms disabled.	
SR/CR 3.9	Protection of Audit Information	Confirm audit records are protected from unauthorized read/modify/delete (permissions + offload).	Met per SL-3 - verify on the product and capture evidence.	completeness
NDR 3.10	Support for updates	Signed firmware upgrade + rollback; DIN-rail in locked panel; control console + Express-Setup button + SD/USB; seal enclosure. **Ext. tools:** Physical inspection; lab upgrade/rollback test.	Signed updatable with rollback; physical access controlled.	NDR-specific.
NDR 3.11	Physical tamper resistance & detection	Confirm physical tamper resistance/detection (device requirement). **Steps:** for this product this is assessed with the same evidence as **NDR 3.10** above (shared steps); confirm this requirement individually and adjudicate it separately.	Physical tamper resistance & detection verified individually.	NDR-specific.
NDR 3.12	Provisioning Supplier Roots of Trust (Network)	Assess the NDR-specific requirement per objective: Network device shall provision and protect product-supplier roots of trust used to validate firmware/identity.	Met per SL-3 - verify and capture evidence.	NDR completeness
NDR 3.13	Provisioning Asset Owner Roots of Trust (Network)	Assess the NDR-specific requirement per objective: Network device shall support provisioning and protection of asset-owner roots of trust.	Met per SL-3 - verify and capture evidence.	NDR completeness
NDR 3.14	Boot Process Integrity (Network)	Assess the NDR-specific requirement per objective: Network device shall verify the integrity of its boot process/firmware before execution.	Met per SL-3 - verify and capture evidence.	NDR completeness

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 4.1	Information confidentiality	SNMPv3 priv (AES); SSH/HTTPS; disable SSHv1/weak ciphers; TLS 1.2/1.3 on Device Manager. **Ext. tools:** sslscan/testssl.sh (:443); ssh-audit (:22); Wireshark.	Modern TLS/SSH ciphers; SNMPv3 priv; weak protocols disabled.	
SR/CR 4.2	Information Persistence	Confirm sensitive data can be purged/sanitized on decommission or re-use.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR/CR 4.3	Use of cryptography	Confirm use of modern cryptography (strong suites, managed keys; weak/legacy disabled). **Steps:** for this product this is assessed with the same evidence as **SR/CR 4.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Use of cryptography verified individually.	

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 5.1	Network segmentation	VLAN/PVLAN + ACL segmentation; unused ports in black-hole VLAN + `shutdown`; Smartports/macros applied per role; verify `show vlan brief`, `show access-lists`. **Ext. tools:** Nmap across VLANs; ACL review.	Effective segmentation; inter-zone flows restricted to policy.	
SR/NDR 5.2	Zone boundary protection	ACLs / CoPP at the cell/area boundary; VTY `access-class`; restrict CIP 44818 to the Logix zone. **Ext. tools:** Nmap at boundary; ACL review.	Boundary enforces least-flow; CIP scoped to its zone.	
SR/NDR 5.3	General Purpose Person-to-Person Communication Restrictions	Assess per objective: Prevent general purpose messages from external users/systems.	Met per SL-3 - verify on the product and capture evidence.	completeness
SR 5.4	Application Partitioning	**N/A.** Single-purpose device; no separable applications to partition (handled at the host/SCADA layer).	N/A - justification recorded (not assessed as a control).	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 6.1	Audit log accessibility	Central syslog (`logging host`); `show logging`; SNMPv3 traps + NetFlow to SIEM/collector; monitor security counters. **Ext. tools:** Syslog listener (`nc -lu 514`); passive OT monitor; SIEM.	Logs/flows/traps centralized and monitored; alerting active.	
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.1	Denial-of-service protection	CoPP, `storm-control`, `ip dhcp snooping`, dynamic ARP inspection, `spanning-tree bpduguard`, `switchport port-security`. **Ext. tools:** Traffic generator / flood test (ISOLATED); counters.	Switch stays manageable/forwarding under storm; protections active.	
SR/CR 7.2	Resource Management	Assess per objective: Limit resource use by security functions to prevent exhaustion.	Met per SL-3 - verify on the product and capture evidence.	completeness

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / firmware
SR/CR 7.3	Control system backup	Config archive + scheduled `write memory`; SCP backup; restore via `configure replace` / SD; test on a spare. **Ext. tools:** SCP backup; `sha256sum` of config; lab restore.	Verified config backup; restore/rollback tested.	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR/CR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security config settings	Document + baseline all settings; capture in archive; change-control changes. **Ext. tools:** RANCID/Oxidized baseline compare.	Settings documented, baselined, change-controlled.	
SR/CR 7.7	Least functionality	Disable unused services: `no ip http server` (use HTTPS), Telnet, `no cdp run` where not needed, `no ip bootp server`; disable/limit CIP if unused; `shutdown` unused ports; SNMPv3-only. **Ext. tools:** Nmap (open services); config review.	Only required services/ports enabled; insecure services off.	
SR/CR 7.8	Component inventory	`show version` / `show inventory`; Studio 5000 AOP shows the switch in the Logix tree with catalog/firmware. **Ext. tools:** ReadOnlyEnum; passive OT monitor.	Complete catalog/firmware inventory captured.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Console / SSH (IOS / IOS-XE CLI)	Native config review (all)	Authenticated CLI; run `show` commands read-only with a least-privilege account.	Read-only; no changes on production.
Device Manager (HTTPS) / Studio 5000 AOP	Config review via web / Logix (1.1, 7.8)	Review users, ports, security, and inventory via Device Manager or the Studio 5000 Add-on Profile.	HTTPS only; authorized account.
RADIUS / TACACS+ client (ISE)	AAA authn/authz/accounting (1.1, 2.1, 2.8)	Test identities; verify authentication, command authorization, and accounting logs.	Test identities; review server logs.
Nmap	Port/service exposure & segmentation (1.13, 5.x, 7.7)	`nmap -sT -p 22,23,80,443,161,44818 -T2` ; scan per VLAN to prove segmentation; confirm 23/80 closed.	Tune timing on production.
sslscan / testssl.sh / ssh-audit	TLS & SSH strength (1.8, 3.8, 4.x)	`sslscan :443`; `ssh-audit` ; confirm strong ciphers/KEX; weak/legacy disabled.	Read-only.
Wireshark / tcpdump	Comm integrity, MACsec, CIP (1.2, 3.1)	SPAN/tap; confirm encrypted mgmt, MACsec, EAPOL/MKA; inspect CIP (enip 44818) exposure.	Passive; SPAN/tap only.
802.1X test supplicant / rogue device	Port authentication (1.2)	Present authorized/unauthorized endpoints on an 802.1X/MAB port; confirm grant vs deny/quarantine.	Coordinate with NAC team.
Syslog server / SIEM + NetFlow	Audit & monitoring (2.8, 6.x)	Confirm logs, accounting, and flows arrive; trigger an event and verify receipt.	Coordinate with SIEM team.
RANCID / Oxidized	Config integrity & drift (3.3, 7.6)	Automated capture; diff running config vs baseline to detect drift.	Read-only.
Hydra / Medusa	Login lockout (1.11)	Authorized repeated logins to confirm login-block/quiet-mode.	ISOLATED/authorized only.
Traffic generator / flooder	DoS resilience (7.1)	Storm/flood test to confirm CoPP/storm-control hold.	ISOLATED/non-production; authorization.

Tool / method	Verifies	How to use — steps / example	Constraints
ReadOnlyEnum	Host/network enumeration (7.8)	Enumerate exposed services/ports read-only.	Read-only.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.